

گزارش تغییرات و راهنمای تست

تغییرات پنل ادمین، سایت، صفحه‌ی «همکاری با لوپ» و بک‌اند اپ‌های کاربر، سازمانی و تکنسین – بر اساس پوشه‌های «پنل» و «سایت»

۶

ایراد امنیتی رفع شده

۶۳

تست خودکار جدید (همه پاس)

+۴۰

endpoint جدید یا تغییرکرده

۵

بخش اصلی کار

فهرست و نحوه‌ی استفاده

- آماده‌سازی محیط تست (یک بار)
- بخش الف – پنل ادمین (تکنسین)
- بخش ب – اصلاحات سایت و مقالات
- بخش ج – صفحه و فرایند «همکاری با لوپ»
- بخش د – بک‌اند اپ کاربر و سازمانی
- بخش هـ – امنیت حساب اپ تکنسین
- ایرادهای امنیتی که در مسیر رفع شد
- تست‌های خودکار
- کارهای باقی‌مانده و تصمیم‌های لازم
- پیوست: فهرست endpoint ها و مجوزهای جدید

هر مورد در جدول‌ها سه ستون دارد: **چه تغییری داده شد**، **مراحل تست و نتیجه‌ی درست**. برچسب‌ها نشان می‌دهند تست کجا انجام می‌شود:

سایت · در مرورگر · پنل · در پنل ادمین (/admin) · API · با Postman یا اپ

قرارداد نمونه‌ها: در مثال‌ها {BASE} آدرس سرور است (مثلاً http://localhost:8001 روی سیستم توسعه) و {TOKEN} توکنی است که از ورود گرفته می‌شود. تمامی درخواست‌های API هدر Accept: application/json دارند و درخواست‌های محافظت‌شده هدر Authorization: Bearer {TOKEN}.

خلاصه‌ی کارهای انجام‌شده

بخش	کارها
الف) پنل	اصلاح متن کیف پول تکنسین، شرط سال تولد غلتان برای ثبت‌نام تکنسین، یکسان‌سازی گزینه‌های نظام وظیفه با اپ
ب) سایت	لینک «دانلود اپلیکیشن‌های هوشمند»، اصلاح «فرایند»، تعویض عکس‌های هدر، ورود ۲۸ مقاله
ج) همکاری با لوپ	صفحه‌ی سایت + فرم ۹ بخشی + کد پیگیری و پیامک + اعلام وضعیت؛ در پنل: درخواست‌ها، فرم‌گزینش و مصاحبه، تاریخچه، پرونده‌ی استخدامی با بخش محرمانه
د) اپ کاربر/سازمانی	اطلاعات تکنسین و حذف شماره، خلاصه‌ی سفارش، عیوب سرویس/محصول، روش و کانال پرداخت، اطلاعات سازمان، مدارک و کاربران مجاز، نسخه‌ی اپ، پورسانت کد معرف، امنیت حساب کامل (دستگاه‌ها، نشست‌ها، فعالیت‌ها، هشدارها، موبایل، دومرحله‌ای، حذف حساب)
ه) اپ تکنسین	ثبت دستگاه هنگام ورود، دستگاه‌های فعال، خروج از سایر دستگاه‌ها، نشست‌ها، IP آخرین اتصال

۱. آماده‌سازی محیط تست

این مراحل یک بار روی سروری که می‌خواهید تست کنید (توسعه یا staging) اجرا می‌شود. روی سیستم توسعه‌ی محلی همه‌ی این مراحل قبلاً انجام شده است.

۱-۱. دستورات استقرار

```
php artisan migrate --force          # جدید migration 9
php artisan permissions:sync         # مجوزهای جدید پنل + اختصاص به مدیر کل
php artisan storage:link              # اگر قبلاً انجام نشده
php artisan blog:import-articles     # ورود 28 مقاله (تکرار آن مشکلی ندارد)
php artisan config:cache && php artisan route:cache
```

فایل‌های جدید در `public/` (عکس‌های هدر و صفحه‌ی همکاری) هم باید روی سرور کپی شوند.

۱-۲. تنظیمات

مورد	توضیح
پیامک همکاری	در پنل sms.ir یک قالب با متن سند «صفحه همکاری در سایت» و پارامتر <code>TRACKINGCODE</code> بسازید و شناسه‌ی آن را در <code>.env</code> بگذارید: <code>SMSIR_COOPERATION_REQUEST_TEMPLATE_ID=...</code> . بدون آن فرم کار می‌کند ولی پیامک نمی‌رود.
Cron	<code>php artisan schedule:run</code> * * * * * - برای اجرای خودکار حذف حساب‌های عادی بعد از ۱۴ روز.
شاهکار	استعلام کد ملی فرم همکاری از تنظیمات فعلی شاهکار استفاده می‌کند. اگر سرویس در دسترس نباشد درخواست با وضعیت «استعلام نشده» ثبت می‌شود.

۱-۳. حساب‌های لازم برای تست

- یک مدیر کل در پنل (همه‌ی مجوزها).
- یک ادمین با دسترسی محدود (برای تست بخش محرمانه‌ی پرونده‌ی استخدامی): فقط «مشاهده/ویرایش پرونده‌های استخدامی» بدون «اطلاعات محرمانه».
- دو کاربر عادی، یک کاربر سازمانی/شرکتی، و یک تکنسین تأییدشده.
- یک گوشی واقعی با شماره‌ی خودتان برای تست پیامک‌ها، و یک اپ احراز هویت (Google Authenticator یا مشابه).

۱-۴. گرفتن توکن برای تست API

```
# کاربر عادی
curl -X POST {BASE}/api/auth/login -H "Accept: application/json" \
  -d phone=09xxxxxxxxx -d password=*****

# سازمان
curl -X POST {BASE}/api/organization/login -H "Accept: application/json" \
  -d organization_code=123456 -d password=*****

# تکنسین (فیلدهای دستگاه اختیاری‌اند)
curl -X POST {BASE}/api/technician/login -H "Accept: application/json" \
  -d referral_code=123456 -d password=***** -d device_id=test-phone-1 -d platform=android
```

۲. بخش الف – پنل ادمین (تکنسین)

تغییر	مراحل تست	نتیجه‌ی درست
متن موجودی کیف پول پنل	تکنسین‌ها ← ویرایش یک تکنسین	کادر سبز بالای فرم: «موجودی کیف پول تکنسین: ۱۲۳,۰۰۰ تومان» (با فاصله و بدون غلط)
شرط سال تولد پنل API	۱. تکنسین ← ایجاد؛ تاریخ تولد 1390/01/01 ← ذخیره. ۲. همین با 1387/12/29 . ۳. ویرایش تکنسینی که قبلاً ثبت شده بدون تغییر تاریخ تولد. ۴. POST :API /api/technician/register با . birth_date=1390-01-01	۱ و ۴: خطا «ثبت‌نام تکنسین فقط برای متولدین سال ۱۳۸۷ و قبل از آن امکان‌پذیر است.» ۲: ذخیره می‌شود. ۳: بدون خطا ذخیره می‌شود (رکوردهای قدیمی قفل نمی‌شوند). از ۱ فروردین ۱۴۰۶ سقف خودکار ۱۳۸۸ می‌شود. تاریخ شمسی، میلادی و ارقام فارسی پذیرفته می‌شود.
وضعیت نظام وظیفه پنل API	۱. ویرایش تکنسین ← فیلد «وضعیت نظام وظیفه» را باز کنید. ۲. از اپ تکنسین با گزینه‌ی «معافیت» یا «درانتظار اعزام» ثبت‌نام کنید. ۳. فرم ثبت‌نام وب تکنسین را باز کنید.	همان ۶ گزینه‌ی اپ + «در حال خدمت» (برای رکوردهای قبلی) نمایش داده می‌شود. قبلاً ستون دیتابیس فقط ۳ مقدار را قبول می‌کرد و ثبت‌نام اپ با این گزینه‌ها خطا می‌داد؛ حالا ذخیره می‌شود. مقادیر قدیمی «معاف» و «پایان خدمت» به «معافیت» و «اتمام خدمت» تبدیل شدند.

۳. بخش ب – اصلاحات سایت و مقالات

تغییر	مراحل تست	نتیجه‌ی درست
لینک دانلود اپلیکیشن‌ها سایت	۱. صفحه‌ی اصلی و چند صفحه‌ی دیگر را در دسکتاپ باز کنید. ۲. روی «دانلود اپلیکیشن‌های هوشمند» کلیک کنید. ۳. صفحه را پایین بکشید تا نوار ثابت (sticky) ظاهر شود. ۴. روی موبایل منوی همبرگری را باز کنید.	لینک کنار لوگو با رنگ طلایی لوگو است و به بخش «اپلیکیشن‌های LOOP» صفحه‌ی اصلی می‌رود. در نوار ثابت و منوی موبایل هم هست.
«فرآیند پاسخگویی ما» سایت	صفحه‌ی تماس با ما را در موبایل باز کنید.	عنوان «فرآیند پاسخگویی ما» درست نوشته شده است.
عکس‌های هدر سایت	صفحه‌ی اصلی، حریم خصوصی و مقالات را در دسکتاپ و موبایل باز کنید (یک بار با Ctrl+Shift+R).	عکس‌های جدید نمایش داده می‌شوند: در حریم خصوصی «اطلاعات شخصی» (نه «اشخصی») و در مقالات «یادگیری» (نه «پادگیری»). حجم عکس‌ها حدود ۴ برابر کمتر است. عکس موبایل صفحه‌ی مقالات ارسال نشده بود و همان قبلی مانده.
۲۸ مقاله‌ی جدید سایت پنل	۱. صفحه‌ی «مقالات و آموزش» را باز کنید و چند صفحه جلو بروید. ۲. مقاله‌ی «کامپیوتر چیست؟ تاریخچه و نسل‌های کامپیوتر» (۶۵ عکس) و «نسل‌ها و سری‌های پردازنده‌های اینتل و AMD» (جدول) را باز کنید. ۳. در پنل – مقالات، فهرست را ببینید.	۱۳ مقاله از فایل اول و ۱۵ مقاله‌ی موضوعی از فایل دوم. عکس‌ها و جدول‌ها درست نمایش داده می‌شوند و عکس کاور در متن تکرار نشده است.

تغییر نسبت به برنامه: مقالات بدون دسته‌بندی ثبت شدند. فیلد دسته‌بندی مقاله به جدول دسته‌های خدمات وصل است و ساختن دسته‌ی «آموزش کامپیوتر» آن را در مسیر ثبت سفارش هم نشان می‌داد. مقاله‌های قبلی سایت هم دسته ندارند. فایل دوم یک سند پیوسته با پرسش‌های کوتاه بود؛ پرسش‌های هم‌موضوع در یک مقاله جمع شدند تا مقاله‌ی خیلی کوتاه نداشته باشیم. اسکریپت ساخت: `database/data/build-blog-articles.py`.

۴. بخش ج – صفحه و فرایند «همکاری با لوپ»

۴-۱. صفحه و فرم سایت [سایت](#)

آدرس: {BASE}/careers – از منوی بالا، منوی موبایل و فوتر («همکاری با لوپ») هم در دسترس است.

سناریو	مراحل تست	نتیجه‌ی درست
نمایش صفحه	صفحه را در دسکتاپ و موبایل باز کنید.	هدر «همکاری با لوپ»، متن «آینده را با هم می‌سازیم»، «فرصت‌های تازه در دنیای فناوری» با عکس تعمیر برد، مسیر همکاری، دکمه‌های «همکاری با لوپ» و «استعلام کد پیگیری».
فیلدهای شرطی	۱. جنسیت «آقا» و سپس «خانم» را انتخاب کنید. ۲. عنوان شغلی «تکنسین میدانی» و سپس شغل دیگری را انتخاب کنید. ۳. گزینه‌ی «سایر» در عنوان شغلی، مدرک و حوزه‌ها؛ «مبلغ مشخص» در حقوق.	نظام وظیفه فقط برای آقایان ظاهر می‌شود و اجباری است. بخش ۶ (تکنسین میدانی) فقط برای همان شغل نمایش داده می‌شود و «نوع گواهینامه» فقط وقتی گواهینامه دارد. کادر توضیح «سایر» و «مبلغ» در صورت انتخاب ظاهر می‌شوند.
اعتبارسنجی	فرم را خالی، با کد ملی نامعتبر (مثل 1234567890)، بدون تیک‌های تأیید، و با فایل غیرمجاز (مثلاً exe) ارسال کنید.	پیام‌های فارسی کنار هر فیلد و فهرست خطاها بالای فرم؛ اطلاعات واردشده حفظ می‌شود.
ثبت موفق	فرم را کامل با شماره‌ی موبایل خودتان (به نام خودتان) و یک رزومه‌ی PDF ارسال کنید.	پیام موفقیت با کد پیگیری به شکل PCS-123456. اگر قالب پیامک تنظیم شده باشد، پیامک با همین کد می‌آید. درخواست در پنل با وضعیت «درخواست جدید» دیده می‌شود.
شاهکار	با کد ملی‌ای که با شماره‌ی موبایل مطابقت ندارد ارسال کنید.	خطا: «کد ملی با شماره موبایل واردشده مطابقت ندارد». اگر سرویس شاهکار قطع باشد، ثبت انجام و در پنل «استعلام نشده» نوشته می‌شود.
درخواست تکراری	با همان کد ملی دوباره ثبت کنید.	خطا: درخواست در حال بررسی وجود دارد. بعد از «رد شده»، «انصراف»، «بانک رزومه» یا «تبدیل به کارمند» ثبت دوباره مجاز است.
استعلام کد پیگیری	در بخش پایین صفحه کد پیگیری و موبایل را وارد کنید؛ یک بار با موبایل اشتباه.	با اطلاعات درست: کد، موقعیت شغلی، تاریخ ثبت و یک پیام ساده متناسب با وضعیت (جزئیات داخلی گزینش نمایش داده نمی‌شود). با موبایل اشتباه: «درخواستی ... پیدا نشد».
محدودیت ارسال	بیش از ۵ بار در یک ساعت از یک IP فرم را ارسال کنید.	خطای ۴۲۹ (جلوگیری از اسپم). یک فیلد مخفی هم ربات‌ها را رد می‌کند.

۴-۲. پنل: درخواست‌ها، گزینش و مصاحبه پنل

منوی جدید «همکاری و استخدام» ← «درخواست‌های همکاری».

سناریو	مراحل تست	نتیجه‌ی درست
فهرست و جستجو	فهرست را ببینید؛ با کد پیگیری، نام، موبایل یا کد ملی جستجو کنید؛ فیلتر وضعیت، شغل و جنسیت را امتحان کنید.	تعداد درخواست‌های جدید کنار منو نشان داده می‌شود. جستجوی سراسری پنل هم با کد پیگیری کار می‌کند.
مشاهده‌ی درخواست	روی «مشاهده» بزنید و فایل رزومه را دانلود کنید.	همه‌ی ۹ بخش فرم، جدول کامل مهارت‌ها و لینک دانلود فایل‌ها. فایل‌ها روی دیسک خصوصی‌اند و فقط ادمین دارای مجوز آن‌ها را می‌گیرد (لینک مستقیم برای دیگران ۴۰۳).
فرم گزینش	«گزینش» را بزنید. در تب‌ها (بررسی رزومه، تماس و دعوت، مصاحبه با ارزیابی، آزمون تخصصی، تصمیم نهایی، پیشنهاد همکاری، تشکیل پرونده، تأیید نهایی) مقادیری وارد کنید. وضعیت را مثلاً به «دعوت به مصاحبه» تغییر دهید و توضیح بنویسید.	ذخیره می‌شود. در جدول «سوابق و تاریخچه گزینش» پایین صفحه، تغییر وضعیت با توضیح و نام ادمین و «به‌روزرسانی فرم گزینش» با نام بخش‌های تغییرکرده ثبت می‌شود. استعلام کد پیگیری در سایت پیام جدید را نشان می‌دهد.
مصاحبه‌ی چندمرحله‌ای	در تب «مصاحبه» دو مرحله اضافه کنید و جدول ارزیابی ۷ شاخصه را پر کنید.	هر مرحله جداگانه ذخیره و نمایش داده می‌شود.
ثبت اقدام دستی	در جدول تاریخچه «ثبت اقدام / یادداشت» را بزنید و یک پیوست اضافه کنید.	ردیف جدید با نام شما، توضیح و تعداد پیوست.
درخواست حضوری/تلفنی	در فهرست «ثبت درخواست حضوری/تلفنی» را بزنید و منبع را «مراجعه حضوری» بگذارید.	درخواست با کد پیگیری جدید و منبع درست ساخته می‌شود.

۴-۳. پرونده‌ی استخدامی پنل

سناریو	مراحل تست	نتیجه‌ی درست
تشکیل از روی درخواست	وضعیت یک درخواست را «پذیرفته شده» کنید. در صفحه‌ی مشاهده‌ی آن «تشکیل پرونده استخدامی» را بزنید.	پرونده‌ی پیش‌نویس با اطلاعات متقاضی و تصمیم نهایی ساخته می‌شود، وضعیت متقاضی «تبدیل به کارمند» می‌شود و صفحه‌ی ویرایش پرونده باز می‌شود.
بخش‌های پرونده	۱۰ تب را بررسی کنید. نوع را «تکنسین» بگذارید.	تب «اختصاصی تکنسین» فقط برای تکنسین نمایش داده می‌شود. تب «ثبت سیستمی» ایجادکننده، آخرین ویرایش‌کننده و درخواست مبدأ را نشان می‌دهد.
بخش محرمانه	۱. با مدیر کل تب «مالی و حقوقی (محرمانه)» را پر و ذخیره کنید (شبا، حقوق، ...). ۲. با ادمین بدون مجوز «اطلاعات محرمانه» همان پرونده را باز و یک فیلد عمومی را ویرایش کنید. ۳. دوباره با مدیر کل باز کنید.	ادمین محدود تب مالی را اصلاً نمی‌بیند و ذخیره‌ی او اطلاعات مالی را پاک نمی‌کند. اطلاعات مالی در دیتابیس رمزنگاری شده است. «تاریخچه تغییرات» فقط نام بخش‌ها را ثبت می‌کند، نه مقادیر محرمانه.

۵. بخش د – بک‌اند اپ کاربر و سازمانی

۵-۱. اطلاعات تکنسین و حذف شماره بعد از پایان سفارش API

سناریو	مراحل تست	نتیجه‌ی درست
سفارش جاری	سفارشی با وضعیت ۰ یا ۱ که تکنسین دارد: POST ، GET /api/orders GET /api/orders/detail یا /api/orders/{id}	در technician فقط این‌ها هست: id, name, phone, technician_type, referral_code, profile_photo_path, created_at, is_online, average_rating, completed_orders_count
سفارش پایان‌یافته یا لغوشده	وضعیت سفارش را در پنل ۲، ۳ یا ۴ کنید و همان درخواست‌ها را تکرار کنید.	کلید phone اصلاً در پاسخ نیست. در لیست چت‌ها هم شماره فقط وقتی هست که سفارش جاری با آن تکنسین وجود دارد.
نبود اطلاعات خصوصی	پاسخ‌ها را برای کلیدهای melicode ، bank_shaba_number ، bank_card_number ، wallet ، home_address جستجو کنید.	هیچ‌کدام نیست (قبلاً همه‌ی این‌ها به مشتری فرستاده می‌شد).

۵-۲. خلاصه‌ی سفارش‌ها و «عیوب سرویس / محصول» API پنل

سناریو	مراحل تست	نتیجه‌ی درست
نام محصول	GET /api/orders/summary برای سفارشی که گزارش تکنسین ندارد یا نام محصولش خالی است.	product_name عنوان دسته‌ی خدمت است (نه خالی) و فیلد جدید category_title هم برمی‌گردد.
ثبت گزارش	POST /api/fault-reports با شماره سفارش خودتان، و یک بار با شماره سفارش کاربر دیگر.	سفارش خودتان ثبت می‌شود؛ سفارش دیگران خطای ۴۲۲ «سفارش یافت نشد».
پنل	منوی گزارشات را ببینید.	عنوان «عیوب سرویس / محصول»؛ جدول ستون «توضیحات» هم دارد و صفحه‌ی مشاهده همه‌ی ۷ فیلد را نشان می‌دهد.

۵-۳. روش و کانال پرداخت API پنل

سناریو	مراحل تست	نتیجه‌ی درست
سفارش‌ها و تراکنش‌ها	GET ، GET /api/orders GET /api/orders/{id} و /api/wallet/transactions	هر سفارش و تراکنش payment_method ، payment_channel و remaining_amount دارد. سفارش پرداخت‌نشده: unpaid. پرداخت با درگاه یا کیف پول: app + in_app (یا site برای سفارش وب).
پرداخت درون برنامه	یک سفارش را با کیف پول و یکی را با درگاه پرداخت کنید.	روش in_app ثبت می‌شود. تراکنش کیف پول حالا به سفارش وصل است و شرح پیش‌پرداخت درست نوشته می‌شود.

سناریو	مراحل تست	نتیجه‌ی درست
پرداخت حضوری	پنل ← سفارش‌ها ← «ثبت پرداخت خارج از برنامه» روی یک سفارش پرداخت‌نشده. یک بار کامل و یک بار با «مانده».	سفارش «پرداخت شده» با روش انتخابی (نقدی، کارت به کارت، ...) و کانال «حضوری» یا «سایت». با مانده: روش remaining و مبلغ مانده. یک تراکنش نوع ۴ برای کاربر ثبت می‌شود و در اپ دیده می‌شود.

۴-۵. کد معرف با درصد جداگانه پنل API

سناریو	مراحل تست	نتیجه‌ی درست
دو درصد برای هر کد	پنل ← کدهای معرف ← ایجاد: «درصد تخفیف» ۷ و «درصد پورسانت صاحب کد» ۳. با یک کاربر دیگر - <code>POST /api/referral-codes/check</code> و سفارش با این کد.	پاسخ check همان <code>discount_percent: 7</code> را دارد (پورسانت به خریدار نشان داده نمی‌شود). درصد پورسانت روی سفارش ذخیره می‌شود و ستون «پورسانت سفارش‌های انجام‌شده» در جدول کدها جمع آن را نشان می‌دهد.

پورسانت فعلاً فقط ثبت و نمایش داده می‌شود و خودکار به کیف پول صاحب کد واریز نمی‌شود.

۵-۵. اطلاعات حساب سازمانی پنل API

سناریو	مراحل تست	نتیجه‌ی درست
پروفایل	GET /api/organization/profile	فیلدهای melicode (شناسه ملی سازمان)، registration_number، economic_code، verification_status و verification_reason.
ویرایش	POST /api/organization/update-profile سه فیلد (JSON یا multipart)، سپس در پنل ← درخواست‌های ویرایش ← تأیید.	تا تأیید، در edited_organization دیده می‌شوند و اطلاعات اصلی عوض نمی‌شود. صفحه‌ی بررسی ادمین مقدار فعلی و درخواستی را کنار هم نشان می‌دهد. بعد از تأیید اعمال می‌شوند.
تعليق	پنل ← کاربران ← ویرایش کاربر سازمانی ← «تعليق حساب سازمان» با دليل.	verification_status: suspended با همان دليل؛ سازمان دسترسی کامل ندارد. شماره ثبت و اقتصادی هم در همین فرم قابل ویرایش است.
مدارک سازمان	POST /api/organization/documents (multipart): GET و DELETE {title, file}، ./api/organization/documents/{id} لینک url را بدون توکن در مرورگر باز کنید. در پنل ← «مدارک سازمان‌ها» تأیید/رد کنید.	فقط PDF و تصویر تا ۱۰ مگابایت. لینک امضاشده ۳۰ دقیقه بدون توکن باز می‌شود. سازمان دیگر نمی‌تواند مدرک شما را حذف کند (۴۰۴). وضعیت و دلیل رد در اپ دیده می‌شود.
کاربران مجاز	GET/POST /api/organization/users {full_name, mobile, role} و DELETE ./api/organization/users/{id}	شماره‌ی تکراری ۴۲۲. کاربر عادی ۴۰۳. فهرست در پنل ← «کاربران مجاز سازمان‌ها».

ایراد قبلی رفع شد: ذخیره‌ی کاربر سازمانی در پنل، «نام تجاری»، «نماینده» و «سابقه» را پاک می‌کرد. بعد از ویرایش یک سازمان در پنل، این فیلدها باید باقی بمانند.

۵-۶. بروزرسانی اپلیکیشن پنل API

سناریو	مراحل تست	نتیجه‌ی درست
تنظیم نسخه	پنل ← تنظیمات ← «نسخه‌ی اپلیکیشن‌ها»: اپ کاربر، Android، آخرین نسخه 2.75.0، حداقل 2.70.0، لینک.	GET /api/app/version? platform=android¤t_version=2.74.3 ← update_available: true, force: false با 2.69.0 ← force: true با 2.75.0 ← update_available: false بدون تنظیم ← update_available: false (بدون خطا). پارامتر اختیاری app=technician برای اپ تکنسین.

۷-۵. امنیت حساب کاربر و سازمانی API

همه زیر `/api/account` و برای توکن کاربر عادی و سازمانی. توکن تکنسین خطای ۴۰۳ می‌گیرد. تاریخ‌ها به شکل `2026-10-03T14:25:00+03:30`.

بخش	مراحل تست	نتیجه‌ی درست
خلاصه	<code>GET /api/account/security</code>	<code>mobile</code> ، <code>two_factor</code> ، <code>active_devices_count</code> ، <code>unread_alerts_count</code> ، <code>sessions_supported: true</code>
دستگاه‌ها	۱. با دو گوشی (یا دو توکن) وارد شوید و برای هر کدام <code>POST /api/account/devices/register</code> با <code>device_id</code> متفاوت بزنید. ۲. <code>GET /api/account/devices</code> ۳. <code>DELETE /api/account/devices/{id}</code> برای گوشی دوم. ۴. با همان گوشی دوباره وارد شوید.	دو دستگاه با <code>is_current</code> درست. گوشی دوم بعد از حذف ۴۰۱ می‌گیرد و اعلان هم نمی‌گیرد. حذف دستگاه فعلی ۴۲۲. ورود دوباره روی یک دستگاه، دستگاه تکراری نمی‌سازد. ورود از دستگاه جدید یک هشدار «ورود از دستگاه جدید» می‌سازد.
خروج از سایر دستگاه‌ها	<code>POST /api/account/devices/logout-others</code>	فقط توکن همین درخواست می‌ماند (برخلاف <code>logout-all</code> قبلی که دستگاه فعلی را هم خارج می‌کرد).
نشست‌ها	<code>DELETE</code> و <code>GET /api/account/sessions /api/account/sessions/{id}</code>	فهرست نشست‌ها با وضعیت و <code>is_current</code> ؛ پایان نشست دیگر موفق، نشست فعلی ۴۲۲.
فعالیت‌ها	چند بار با رمز اشتباه و یک بار درست وارد شوید؛ <code>GET /api/account/activities?page=1</code>	ورود موفق و ناموفق با دستگاه، سیستم‌عامل و IP؛ جدیدترین اول، ۲۰ تا. بعد از ۵ ورود ناموفق در ۱۵ دقیقه یک هشدار «چند ورود ناموفق» (فقط یک بار).
هشدارها	<code>POST</code> ، <code>GET /api/account/security-alerts</code> ، <code>PUT</code> ، <code>POST .../read-all</code> ، <code>.../{id}/read</code> ، <code>.../settings {"notifications_enabled": false}</code> ؛ سپس رمز و موبایل را عوض کنید.	هشدارها با سطح اهمیت و اقدام پیشنهادی ثبت می‌شوند. با اعلان خاموش، هشدار «تغییر رمز» push نمی‌شود ولی هشدار <code>critical</code> (تغییر موبایل، تغییر دومرحله‌ای) باز هم push می‌شود.
موبایل	۱. <code>POST /api/account/mobile/send-code</code> با بدنه‌ی خالی <code>POST</code> <code>/api/account/mobile/verify {code}</code> ۲. تغییر: <code>send-code {mobile}</code> ← کد به شماره‌ی جدید می‌رود <code>verify {code, mobile}</code> ۳. شماره‌ی کاربر دیگر را وارد کنید؛ بیش از ۵ بار در ساعت کد بخواهید.	پاسخ: <code>{expires_in: 120, resend_in: 60, remaining_attempts}</code> و تأییدشده می‌شود (ورود بعدی با شماره‌ی جدید). شماره‌ی تکراری ۴۲۲؛ درخواست زودتر از ۶۰ ثانیه یا بیش از ۵ بار در ساعت ۴۲۹. ۵ کد اشتباه کد را باطل می‌کند.

۸-۵. تأیید دومرحله‌ای API

سناریو	مراحل تست	نتیجه‌ی درست
فعال‌سازی با پیامک	<pre>POST /api/account/security/two-factor/send-code {"purpose":"enable","method":"sms"} POST .../two-factor/enable {"method":"sms","code":"..."}</pre>	۸ کد بازیابی به شکل XXXX-XXXX. خلاصه‌ی امنیت «فعال» و روش sms را نشان می‌دهد.
فعال‌سازی با اپ احراز هویت	<pre>send-code {"purpose":"enable","method":"app"} secret یا otpauth_url را در Google Authenticator وارد کنید (یا از otpauth_url یک QR بسازید) {"method":"app","code":"۶ رقمی اپ"}</pre>	فعال می‌شود و هیچ پیامکی ارسال نمی‌شود.
ورود با دومرحله‌ای	<pre>POST /api/auth/login (یا) POST /api/organization/login /api/auth/two-factor/verify {"two_factor_token":"...", "code":"..."}</pre>	ورود اول توکن نمی‌دهد: {success:true, requires_two_factor:true, two_factor_token, method} بعد از کد درست، همان پاسخ ورود معمولی (کاربر یا سازمان) با توکن. کد اشتباه ۴۲۲؛ بعد از ۵ اشتباه یا ۱۰ دقیقه باید دوباره وارد شد.
کد بازیابی	در verify به‌جای کد، یک کد بازیابی وارد کنید؛ دوباره همان را امتحان کنید. سپس two-factor/recovery-codes.	هر کد بازیابی فقط یک بار کار می‌کند. ساخت کدهای جدید کدهای قبلی را باطل می‌کند. کد اپ هم دو بار پذیرفته نمی‌شود.
غیرفعال‌سازی	<pre>disable ← send-code {"purpose":"disable"} {"code":"..."}</pre>	غیرفعال؛ ورود بعدی مستقیم توکن می‌دهد. فعالیت و هشدار critical ثبت می‌شود.

تیم اپ: صفحه‌ی وارد کردن کد هنگام ورود هنوز در اپ نیست. تا اضافه شدنش، کاربری که دومرحله‌ای را روشن کند از اپ نمی‌تواند وارد شود؛ قبل از انتشار، این صفحه باید آماده باشد.

۹-۵. حذف حساب کاربری API پنل

سناریو	مراحل تست	نتیجه‌ی درست
حساب عادی	← POST /api/account/deletion-request/send-code POST /api/account/deletion-request GET ← {"code":"...", "reason":"..."} POST ← /api/account/deletion-request .../cancel	وضعیت approved با scheduled_at ۱۴ روز بعد؛ تا قبل از آن لغو ممکن است. درخواست دوم همزمان ۴۲۲.
اجرای خودکار	روی محیط تست scheduled_at را در دیتابیس به گذشته ببرید و php artisan accounts:process-deletions بزنید.	نام «کاربر حذف‌شده»، اطلاعات شخصی (کد ملی، کارت، شبا، آدرس، ایمیل) پاک، همه‌ی توکن‌ها باطل، ورود ناممکن. سفارش‌ها و تراکنش‌ها باقی می‌مانند. وضعیت done.
حساب سازمانی	همان مراحل با توکن سازمان؛ سپس پنل ← کاربران ← «درخواست‌های حذف حساب» ← تأیید (یا رد با دلیل).	درخواست pending می‌ماند و خودکار اجرا نمی‌شود. با تأیید ادمین بلافاصله اجرا می‌شود؛ با رد، rejected.

۶. بخش ه – امنیت حساب اپ تکنسین

دقیقاً طبق قرارداد سند Backend-Account-Security.md؛ مسیرها زیر `/api/technician/security` . همان چکلیست تست سند:

سناریو	مراحل تست	نتیجه‌ی درست
ورود با اپ جدید	ورود با فیلدهای دستگاه (<code>device_id, platform, device_type, device_brand, device_model, os_name, os_version, app_version</code>)	اطلاعات دستگاه و IP روی همان توکن ذخیره می‌شود.
ورود دوباره روی همان گوشی	دو بار با یک <code>device_id</code> وارد شوید.	فقط یک نشست برای آن دستگاه می‌ماند.
دو گوشی	با دو گوشی وارد شوید؛ <code>GET devices</code> از هر دو.	دو دستگاه؛ <code>is_current</code> روی هر کدام درست.
خروج از یک دستگاه	<code>DELETE devices/{id}</code> برای گوشی دوم.	درخواست بعدی گوشی دوم ۴۰۱ و اپ به صفحه‌ی ورود می‌رود؛ توکن FCM آن گوشی هم حذف می‌شود.
خروج از سایرین	<code>POST logout-others</code>	فقط توکن فعلی می‌ماند؛ <code>revoked_sessions</code> و <code>revoked_devices</code>
محافظ دستگاه فعلی	<code>DELETE devices/{id}</code> و <code>DELETE sessions/{id}</code> روی نشست فعلی.	۴۲۲ با <code>CURRENT_DEVICE / CURRENT_SESSION</code>
نشست تکنسین دیگر	<code>DELETE sessions/{id}</code> با شناسه‌ی توکن تکنسین دیگر.	۴۰۴ و هیچ چیز حذف نمی‌شود.
توکن‌های قدیمی	با توکنی که قبل از به‌روزرسانی ساخته شده <code>PUT current-device</code> بزنید.	اطلاعات دستگاه پر می‌شود.
IP آخرین اتصال	از دو شبکه‌ی مختلف درخواست بزنید.	<code>last_ip</code> با آخرین درخواست عوض می‌شود؛ IP ورود ثابت می‌ماند.
نسخه‌ی قدیمی اپ	ورود بدون فیلدهای دستگاه.	بدون خطا وارد می‌شود.

اگر سرور پشت پروکسی یا CDN است، تا وقتی `trustProxies` تنظیم نشود، IPها به جای IP گوشی، IP پروکسی خواهند بود.

۷. ایرادهای امنیتی که در مسیر رفع شد

این‌ها در درخواست‌ها نبودند ولی هنگام کار پیدا و رفع شدند. هر کدام تست خودکار دارد.

ایراد	چطور تست کنیم	نتیجه‌ی درست
نشت اطلاعات تکنسین به مشتری	بخش ۱-۵	فقط فیلدهای مجاز.
نظرات عمومی تکنسین، اطلاعات مشتری‌ها را برمی‌گرداند	GET /api/reviews/technician/{id} بدون توکن.	از هر نظردهنده فقط نام و عکس؛ بدون موبایل، کد ملی، کارت، شبا و آدرس.
دیدن گزارش سفارش دیگران	GET /api/order-reports/by-order/{id} با شماره سفارش کاربر دیگر.	۴۰۴. صاحب سفارش و تکنسین همان سفارش ۲۰۰.
گزارش عیب با سفارش دیگران	بخش ۲-۵	۴۲۲؛ آدرس و موبایل سفارش دیگران برنمی‌گردد.
پاک شدن فیلدهای سازمان در پنل	بخش ۵-۵	فیلدها باقی می‌مانند.
ثبت‌نام تکنسین با گزینه‌های نظام وظیفه‌ی اپ	بخش ۲	ذخیره می‌شود.

۸. تست‌های خودکار

۶۳ تست جدید در ۱۰ فایل نوشته شد و همه پاس می‌شوند. در کل ۱۴۱ تست پروژه، فقط همان ۲۸ تست قدیمی رد می‌شوند که پیش از این کار هم خراب بودند (تست‌های قدیمی و ناهماهنگ با کد فعلی)؛ تست خراب جدیدی اضافه نشده.

فایل تست	پوشش
TechnicianRegistrationRulesTest	سال تولد غلتان، گزینه‌های نظام وظیفه
CustomerTechnicianPrivacyTest	اطلاعات تکنسین، چت، نظرات، گزارش سفارش، خلاصه‌ی سفارش، عیوب
TechnicianAccountSecurityTest	چک‌لیست کامل سند امنیت حساب تکنسین
UserAccountSecurityTest	دستگاه‌ها، نشست‌ها، فعالیت‌ها، هشدارها، موبایل، دومرحله‌ای، حذف حساب
OrganizationAccountAndPaymentTest	پروفایل سازمان، مدارک، کاربران مجاز، نسخه‌ی اپ، کد معرف، روش پرداخت
CareersPageTest / CareersAdminTest	فرم همکاری، شاهکار، کد پیگیری؛ گزینش، تاریخچه، پرونده‌ی استخدامی و بخش محرمانه
BlogArticlesImportTest / NewAdminPagesSmokeTest	ورود مقالات؛ باز شدن همه‌ی صفحه‌های جدید پنل

اجرا (فقط با دیتابیس تست، نه دیتابیس اصلی):

```
composer test
# یا فقط تست‌های جدید:
php artisan test --filter
"UserAccountSecurity|TechnicianAccountSecurity|Careers|OrganizationAccountAndPayment"
```

هشدار: php artisan test را داخل کانتینر اصلی اجرا نکنید؛ به‌خاطر کَش تنظیمات، دیتابیس MySQL توسعه را پاک می‌کند. از composer test استفاده کنید که اول کَش تنظیمات را پاک می‌کند.

۹. کارهای باقی‌مانده و تصمیم‌های لازم

قبل از انتشار

۱. قالب پیامک همکاری در sms.ir و مقدار `SMSIR_COOPERATION_REQUEST_TEMPLATE_ID`.
۲. Cron برای `schedule:run`.
۳. صفحه‌ی کد دومرحله‌ای در اپ کاربر و سازمانی.
۴. تصمیم درباره‌ی `trustProxies` با توجه به ساختار سرور.
۵. `commit` و ادغام تغییرات (هنوز روی شاخه‌ی `prelunch` و `commit` نشده است).

تصمیم‌های کسب‌وکاری

- پورسانت کد معرف: فعلاً فقط ثبت و نمایش؛ واریز خودکار به کیف پول صاحب کد نیاز به قاعده دارد.
- پرداخت حضوری: سهم تکنسین به کیف پولش واریز نمی‌شود چون پول نقد معمولاً نزد خود تکنسین است.
- کاربران مجاز سازمان: فعلاً فقط فهرست مدیریت می‌شود؛ نحوه‌ی ورود و سطح دسترسی آن‌ها تصمیم بعدی است.
- همکاری و استخدام: فعلاً در همین پنل؛ با راه‌اندازی پنل اتوماسیون منتقل می‌شود. اتصال پرونده به حضور و غیاب، حقوق، انبار و ارزیابی عملکرد (پیشنهاد انتهای سند) هنوز ساخته نشده است.

ایرادهای قدیمی که در این کار دست نخورد

- در API ثبت‌نام تکنسین، «تاریخ اعتبار گواهینامه» و «وسیله‌ی نقلیه» اختیاری‌اند ولی در دیتابیس اجباری؛ ثبت‌نام بدون آن‌ها خطای دیتابیس می‌دهد.
- ورود با «بازیابی رمز» برای کسی که دومرحله‌ای را روی روش اپ دارد، مرحله‌ی دوم را دور می‌زند.
- عکس‌های قدیمی هدر هنوز در `public/assets/new-style/` هستند ولی استفاده نمی‌شوند.

۱۰. پیوست: endpoint ها و مجوزهای جدید

امنیت حساب کاربر و سازمانی

```
GET /api/account/security
POST /api/account/security/two-factor/send-code
POST /api/account/security/two-factor/enable
POST /api/account/security/two-factor/disable
POST /api/account/security/two-factor/recovery-codes
POST /api/auth/two-factor/verify
POST /api/account/devices/register
GET /api/account/devices
DELETE /api/account/devices/{id}
POST /api/account/devices/logout-others
GET /api/account/sessions
DELETE /api/account/sessions/{id}
GET /api/account/activities
GET /api/account/security-alerts
POST /api/account/security-alerts/{id}/read
POST /api/account/security-alerts/read-all
GET|PUT /api/account/security-alerts/settings
POST /api/account/mobile/send-code
POST /api/account/mobile/verify
GET /api/account/deletion-request
POST /api/account/deletion-request/send-code
POST /api/account/deletion-request
POST /api/account/deletion-request/cancel
```

تکنسین

```
GET /api/technician/security/devices
DELETE /api/technician/security/devices/{id}
POST /api/technician/security/logout-others
GET /api/technician/security/sessions
DELETE /api/technician/security/sessions/{id}
PUT /api/technician/security/current-device
```

سازمان، سفارش، اپ

```
GET|POST|DELETE /api/organization/documents
GET|POST|DELETE /api/organization/users
GET /api/orders/{id} (معاذل)
POST /api/orders/detail
GET /api/app/version
```

سایت

```
GET /careers
POST /careers
POST /careers/track
```

دستورات artisan

```
blog:import-articles
accounts:process-deletions (ساعتی، با scheduler)
```

مجوزهای جدید پنل

کاربرد	مجوز
صف درخواست‌های حذف حساب	view / edit-account-deletion-requests
نسخه‌ی اپلیکیشن‌ها	view / edit-app-versions
درخواست‌های همکاری و فرم‌گزینش	view / edit / delete-cooperation-requests
پرونده‌های استخدامی (بخش عمومی)	view / edit-employment-files
بخش محرمانه‌ی مالی و بانکی پرونده – فقط منابع انسانی و افراد مجاز	view-employment-confidential

«مدارک سازمان‌ها» و «کاربران مجاز سازمان‌ها» از مجوزهای موجود کاربران (view-user / edit-user) استفاده می‌کنند. بعد از permissions:sync مدیر کل همه را دارد؛ برای نقش‌های دیگر از بخش نقش‌ها اختصاص دهید.